

SecureForge Web

Relatório de Postura de Segurança

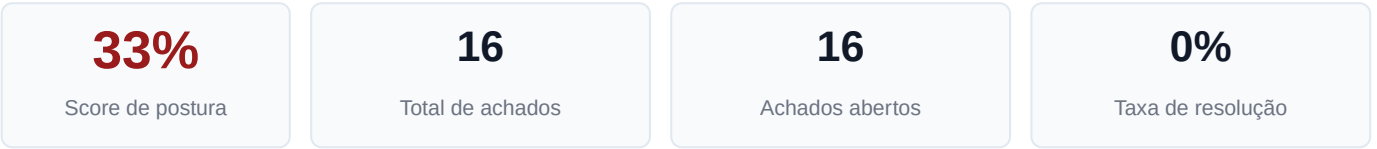
Gerado em 24/07/2026, 16:48:45

Identificação da aplicação

OWASP WebGoatPHP

Stack: PHP + HTML + CSS + JavaScript
Análise: Análise 24/07/2026 — Checklist Essential SecureForge v1.0
Concluída em: 24/07/2026
Gerado por: SecureForge Web (secureforgeweb@gmail.com)

Resumo executivo



Achados por severidade

Crítica: 5
Alta: 6
Média: 5

Plano de ação priorizado

- AUTH-02 — Hash de senha forte**
Crítica · Imediata · Aberto · Autenticação
Ação recomendada: Adote bcrypt (custo 12+) ou Argon2id para hash de senhas.
- AUTHZ-03 — Rotas administrativas protegidas**
Crítica · Imediata · Aberto · Autorização
Ação recomendada: Exija autenticação + autorização admin em todas as rotas /admin.
- SECRET-01 — Segredos em variáveis de ambiente**
Crítica · Imediata · Aberto · Proteção de credenciais
Ação recomendada: Use .env (não versionado) ou vault; nunca commite credenciais.
- SECRET-02 — Ausência de credenciais no repositório**
Crítica · Imediata · Aberto · Proteção de credenciais
Ação recomendada: Execute varredura de segredos e rotacione credenciais expostas.
- DATA-01 — HTTPS/TLS em trânsito**
Crítica · Imediata · Aberto · Dados sensíveis
Ação recomendada: Configure TLS em todos os ambientes acessíveis externamente.
- AUTH-01 — Política de senha mínima**
Alta · Curto prazo · Aberto · Autenticação
Ação recomendada: Exigir 8+ caracteres com maiúscula, minúscula, número e especial.

AUTHZ-02 — Princípio do menor privilégio

Alta · Curto prazo · Aberto · Autorização

Ação recomendada: Audite papéis e remova acessos desnecessários.

INPUT-01 — Validação server-side

Alta · Curto prazo · Aberto · Validação de entrada

Ação recomendada: Implemente validação com schema (Joi/Zod) em todos os endpoints.

INPUT-03 — Sanitização anti-XSS

Alta · Curto prazo · Aberto · Validação de entrada

Ação recomendada: Escape output, use CSP e frameworks que sanitizam por padrão.

HEADER-01 — Content-Security-Policy

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Defina Content-Security-Policy adequada ao tipo de aplicação.

HEADER-02 — Strict-Transport-Security

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Configure Strict-Transport-Security em produção.

AUTH-04 — Expiração de sessão

Média · Médio prazo · Aberto · Autenticação

Ação recomendada: Defina timeout de sessão e renovação segura de tokens.

HEADER-03 — X-Frame-Options / frame-ancestors

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Use X-Frame-Options: DENY ou CSP frame-ancestors.

HEADER-04 — X-Content-Type-Options

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Defina X-Content-Type-Options: nosniff.

EXPOS-02 — Documentação de API restrita

Média · Médio prazo · Aberto · Exposição de endpoints

Ação recomendada: Proteja ou desabilite docs de API em ambiente de produção.

SURF-01 — Portas e serviços desnecessários

Média · Médio prazo · Aberto · Superfície de ataque

Ação recomendada: Desative portas, debug endpoints e serviços não utilizados.

